

IT Security: Unit 3 Question Bank

Topics: Software and Operational Security | Cloud Computing

SECTION A : QUESTIONS

Q.No	Question	Marks	Bloom's Level
1	What is meant by 'rogue software', and why is it more dangerous than standard malware types?	2M	BTL-1 (Remember)
2	What role does the Calls Detail Record (CDR) play in the operational security of telecom companies?	2M	BTL-1 (Remember)
3	How does the concept of Authorization differ from Authentication in the context of software access controls?	2M	BTL-2 (Understand)
4	Trace the journey of how software is broadly categorised in organisations, and point out which categories raise the highest security concerns.	5M	BTL-2 (Understand)
5	A bank's software development team is about to release a new internet banking module. Walk through the testing methodologies they should follow before going live, with special focus on the security risks each stage addresses.	5M	BTL-3 (Apply)
6	A BPO company handling customer data for a foreign bank is setting up its operations security framework. What are the major threat areas it must prioritise, and how should it approach third-party access controls?	5M	BTL-3 (Apply)
7	Compare White Box Testing and Black Box Testing in terms of their approach, knowledge requirement, and their specific relevance to catching security vulnerabilities in banking software.	6M	BTL-4 (Analyse)
8	Analyse how VoIP Eavesdropping poses a threat to operational security in the telecom industry, and examine the measures that should be in place to counter it.	6M	BTL-4 (Analyse)
9	Evaluate the claim that 'the human element is the weakest link in security', particularly in the context of Operational Security across industries. Is this still true in today's automated banking environment?	6M	BTL-5 (Evaluate)
10	The steps involved in Operational Security have been listed in the textbook. Taking a banking scenario as your base, walk through each step in order and show how it plays out in real banking operations.	8M	BTL-4 (Analyse)
11	Critically examine Cloud Computing as an infrastructure choice for banks, weighing its operational benefits against the security and compliance risks it introduces.	8M	BTL-5 (Evaluate)
12	You are tasked with designing a Software Security framework for a mid-sized private bank that has just shifted to a fully digital banking model. What techniques and controls would you put in place, and how would you justify each choice?	8M	BTL-6 (Create)
13	Evaluate the security architecture required for banks moving towards a paperless, Core Banking-driven environment. Consider the roles of software controls, operational	10M	BTL-5 (Evaluate)

	procedures, and user-level controls in building a secure banking ecosystem.		
14	Construct a comprehensive Operational Security policy framework for a mid-sized BPO company that handles financial data for multiple banking clients. Your framework should address personnel, technology, third-party access, and compliance.	10M	BTL-6 (Create)
15	Drawing from the concepts of Software and Operational Security, construct a Security Audit checklist for a bank that is about to go live with a new Core Banking Solution. Your checklist should span software testing, access controls, operational readiness, and cloud infrastructure (if applicable).	10M	BTL-6 (Create)

SECTION B: ANSWERS

Q1. What is meant by 'rogue software', and why is it more dangerous than standard malware types?

Answer: Rogue software is any software that is unauthorised and unintended which runs without proper consent of the owner and causes damage to computer resources or systems.

Malware falls under this umbrella and is specifically written to cause harm or other loss to a system. Security managers must stay vigilant about rogue software far more than standard types like system software or off-the-shelf applications, because rogue software is designed to bypass normal controls and operate in the shadows.

Q2. What role does the Calls Detail Record (CDR) play in the operational security of telecom companies?

Answer: A CDR is a record maintained by telecom providers that captures details such as the calling number, called number, duration of the call, type of call, and communication success or failure.

Under the IT Act, 2000, e-records are legally valid, and it is the responsibility of telecom companies to preserve and produce CDRs whenever required, especially in the event of disputes or investigations. This makes CDR management a key part of operational security for any telecom organisation.

Q3. How does the concept of Authorization differ from Authentication in the context of software access controls?

Answer: Authorization is the process of granting permission to someone to access or perform a specific action. For instance, allowing only authorised personnel to enter a server room.

Authentication, on the other hand, is the process of verifying who someone actually is. when a user enters their ID and is asked for a password, that verification process is authentication.

In practice, authentication happens first (verifying identity), followed by authorization (granting access). Both work together to defend against a wide range of application security threats.

Q4. Trace the journey of how software is broadly categorised in organisations, and point out which categories raise the highest security concerns.

Answer: Software in organisations can be broadly placed into five categories:

1. System Software: Operating systems like Windows, Linux, Unix, or IOS (Cisco routers) that run the hardware. Mobile OS like Android also falls here.
2. Application Software: Purpose-built software like Core Banking Solutions (BaNCS by TCS, Flexcube by iFlex, Finacle by Infosys) for specific business tasks.
3. Apps: Self-contained mobile or internet programs downloaded for a specific purpose, commonly used on smartphones.
4. Off-the-shelf Software: Standardised tools like MS Office or Adobe Photoshop, available across industries.
5. Open-Source Software: Freely available software whose source code can be customised, like Linux distros.

From a security standpoint, rogue software (including malware and adware) is the biggest concern. Adware automatically plays or downloads advertisements while browsing. Malware is written specifically to damage systems. Security managers must ensure that the IS Policy, especially in areas of Access Control, Authorization, and Authentication, covers all software types running in the organisation.

Q5. A bank's software development team is about to release a new internet banking module. Walk through the testing methodologies they should follow before going live, with special focus on the security risks each stage addresses.

Answer: A proper software release in a bank must pass through several layers of testing:

1. Unit Testing: Developers test individual modules for functionality against design specs.
2. White Box Testing: Internal logic is examined by reading source code; naming conventions, design documents, and coding standards are all reviewed. This catches embedded vulnerabilities in logic.
3. Black Box Testing (Verification and Validation): Inputs and outputs are tested without reading code; no programming knowledge needed. This reflects how an external attacker might probe the system.
4. Integration Testing: Each module is tested with others to ensure they work together as a system.
5. Volume and Stress Testing: Simulates high traffic to check if the system holds up under load, important for an internet banking module with thousands of concurrent users.
6. Security Testing: This is the most critical stage for a banking module. It checks compliance with IS Policy, verifies Access Privileges, handles threats like DoS, DDoS, and phishing. Firewall placement and DMZ (Demilitarized Zone) configurations are reviewed here.
7. User Acceptance Testing (UAT): Program output is presented to actual users for sign-off.
8. Alpha and Beta Testing: Near-final testing in virtual and real environments before release.

Q6. A BPO company handling customer data for a foreign bank is setting up its operations security framework. What are the major threat areas it must prioritise, and how should it approach third-party access controls?

Answer: BPO (Business Process Outsourcing) and KPO (Knowledge Process Outsourcing) companies handle large volumes of sensitive customer data, which makes their security posture especially critical. The five major threat areas to prioritise are:

1. Threats posed by employees: Insider threats are the most common vector in BPO environments.

2. Unrestricted use of external devices or communication via email USB drives, personal phones, and unmonitored emails are common data leakage channels.
3. Inadequate or missing security audits: Without regular audits, vulnerabilities go undetected.
4. Ambiguous responsibility assignment: If no one clearly owns security accountability, gaps emerge.
5. Poorly monitored third-party access: Vendors and contractors with unrestricted access are a major risk.

For third-party access, Service Level Agreements (SLAs) must clearly restrict access to critical areas, and must include penalty clauses or arbitration provisions in the event of any security breach. The famous arrest of the CEO of "baazee.com" in 2004 is a reminder that corporate entities are held responsible for the actions of their employees and contractors — making proper access controls not just good practice, but a legal necessity.

Q7. Compare White Box Testing and Black Box Testing in terms of their approach, knowledge requirement, and their specific relevance to catching security vulnerabilities in banking software.

Answer: White Box Testing involves reading the entire source code of the program and verifying its internal logic against user requirements. The tester needs a thorough understanding of the programming language, high-level and low-level design documents, coding standards, and naming conventions. This method is highly effective at catching embedded backdoors, trapdoors, and logic flaws.

Black Box Testing, also called Verification and Validation Testing, tests the software purely from the outside by feeding in inputs and checking outputs, without any knowledge of the source code. It does not require programming expertise, making it closer to how an external attacker would interact with the system.

In a banking context:

- White Box Testing is the only way to catch a Salami Attack: a fraud technique where a programmer writes code to round off interest amounts and credit the difference to a personal account. This can only be detected by a careful code walkthrough or a discerning auditor noticing unusual credits in one account.
- Black Box Testing is suited for testing the user interface, input validations, and access flows. For instance, verifying that an ATM or Internet Banking login correctly rejects invalid credentials.

Together, both methods must be used as one complements the other. Relying on only one leaves either the internal logic or the external interface unguarded.

Q8. Analyse how VoIP Eavesdropping poses a threat to operational security in the telecom industry, and examine the measures that should be in place to counter it.

Answer: VoIP (Voice over Internet Protocol) is a technology that converts analog voice signals into digital data packets and transmits them in real time using the IP protocol over the internet.

The threat — VoIP Eavesdropping arises because: once voice is converted to IP packets, it travels over a network. Freely available software tools can capture these packets as they traverse the network, and separate tools exist that can reconstruct those packets back into audible voice conversations. In simple terms, anyone with the right tools and network access can listen in on calls.

Why this matters for telecom operational security:

- Telecom companies are custodians of customer data to a very large extent
- They are bound by the IT Act's 'Due Diligence' requirements
- NSPs (Network Service Providers) must protect not just against external threats but also internal employee fraud

Countermeasures that should be in place:

1. Encryption of VoIP packets so that even if intercepted, the data is unreadable
2. Strong authentication for VoIP devices and communication channels
3. Monitoring and logging of VoIP traffic for anomalies
4. Restricting access to network infrastructure that carries voice data
5. Regular security audits of telecom channels

The operational security framework of any NSP must treat VoIP Eavesdropping as a first-class threat rather than an afterthought.

Q9. Evaluate the claim that 'the human element is the weakest link in security', particularly in the context of Operational Security across industries. Is this still true in today's automated banking environment?

Answer: The claim that the human element is the weakest link in security is not just a slogan — it is backed by practical evidence across industries.

Why the claim holds:

- Security is not a 100% automated process; it is humans who implement it. Opportunities, greed, or pressure can tempt individuals to exploit vulnerabilities they encounter
- In banks, insider threats manifest as deliberate misconfigurations, non-observance of procedures, or intentional ignoring of warning signals
- In BPO environments, employees with unrestricted device access are a primary data leakage channel
- In software development, trapdoors are inserted by programmers during repeated testing phases

Even in today's automated banking environment, the argument remains valid because:

- Core Banking Systems and e-governance reduce manual intervention, but the people who configure, administer, and maintain these systems are still human.
- Social engineering attacks (phishing, impersonation) target employees, not machines.
- The Gopalakrishna Working Group of RBI recognised this and specifically recommended training and awareness programs not just for staff but also for customers.

However, a nuance is needed. Technology does reduce the number of decision points where humans can err. Automation, audit trails, and maker-checker principles shrink the window of opportunity for human-driven fraud. So while humans remain the weakest link, good governance reduces the surface area of that weakness significantly.

Q10. Operational Security in any organisation is carried out through a series of well-defined steps. Using a banking scenario, walk through each of these steps in order and illustrate how they manifest in real banking operations

Answer: Operational Security is the part of security that deals with protecting the core activity of an organisation. In a bank, the core activity revolves around transactions — from the moment a customer enters a branch to the settlement of funds. The seven steps of Operational Security, applied to banking, work as follows:

1. Identification of critical information: In a bank, this includes account data, transaction records, customer KYC information, CBS (Core Banking Solution) configurations, and RTGS/NEFT data. These are the crown jewels.
2. Treatment of such information (Classification): Data is classified by sensitivity — public data (interest rates), internal data (customer details), confidential data (account balances, PINs), and restricted data (CBS access credentials). Each class gets different levels of protection.
3. Identification of threats and vulnerabilities: Threats include phishing attacks on internet banking users, DoS/DDoS attacks on bank servers, insider fraud, ATM skimming, and VoIP eavesdropping on treasury calls.
4. Risk Analysis and Risk Management: Each identified threat is assessed for likelihood and impact. ATM fraud may be frequent but low-value per incident; a CBS configuration breach may be rare but catastrophic. Risk prioritisation follows this analysis.
5. Planning for Risk Mitigation and Risk Controls: This is where policies are written — access control policies, password policies, maker-checker principles, and session management for internet banking.
6. Application of security measures: Implementation: firewalls, DMZ configurations for internet-facing systems, two-factor authentication for internet banking, biometrics at ATMs, and encryption of data at rest and in transit.
7. Monitoring effectiveness and initiating corrective and preventive action: Any transaction that falls outside routine parameters is captured through exception reports, covering cases such as temporary overdrafts and improperly introduced accounts. Such reports are escalated to the appropriate authority for immediate corrective measures, while periodic reviews ensure that the overall control framework remains adequate and effective.

Drafting this framework in a bank requires co-ordination across systems, HR, technology, top management, and compliance — all working together as a multi-pronged effort.

Q11. Critically examine Cloud Computing as an infrastructure choice for banks, weighing its operational benefits against the security and compliance risks it introduces.

Answer: Cloud Computing is a model where computing resources such as software, storage, processing power are made available over the internet on a pay-as-you-go basis, rather than being owned and maintained in-house.

The three main service models relevant to banks are IaaS (Infrastructure as a Service), PaaS (Platform as a Service), and SaaS (Software as a Service).

Operational Benefits for Banks:

1. Rapid deployment — New services can be rolled out much faster than on-premise setups.
2. Significantly reduced operating costs — No capital expenditure on hardware.
3. Massive economies of scale — Cloud providers run at a scale banks cannot match individually.
4. Agility — The bank can scale up during peak periods (year-end, festive seasons) and scale down otherwise.
5. Disaster recovery — Cloud providers offer geo-redundant storage, improving resilience.

Security and Compliance Risks:

1. Data sovereignty — Customer data may reside on servers in foreign jurisdictions, conflicting with RBI's data localisation requirements.

2. Shared infrastructure risks — In public clouds, a bank's data may share physical hardware with other tenants, raising the risk of side-channel attacks.
3. Compliance complexity — Banks must comply with RBI, SEBI, TRAI, and CERT-In guidelines. Ensuring a cloud provider meets all these is non-trivial.
4. Authentication and access control — Cloud environments require robust IAM (Identity and Access Management) to prevent unauthorised access.
5. Vendor lock-in and SLA gaps — If the cloud provider experiences downtime, the bank's services go down too, and SLA penalties may not compensate for reputational damage.

Verdict: Cloud is not a no-go for banks, but it demands a governance-first approach. Compliance with ISMS, possibly ISO 27001 certification of the cloud provider, and a well-drafted SLA with clear security obligations are the minimum requirements before a bank considers cloud migration.

Q12. You are tasked with designing a Software Security framework for a mid-sized private bank that has just shifted to a fully digital banking model. What techniques and controls would you put in place, and how would you justify each choice?

Answer: A fully digital bank is essentially a software-centric organisation. Its vault is its codebase, its teller counter is an app, and its ledger is a database. Building security into this environment from the ground up requires a layered approach.

- **Layer 1 — Patch Management**

Software vulnerabilities are discovered continuously. A rigorous patch management process ensures that vulnerabilities are fixed as soon as they are identified. In a digital bank, even a 24-hour lag in patching a known vulnerability in the internet banking stack can be exploited. Justification: The cost of a breach far exceeds the cost of maintaining a patch cycle.

- **Layer 2 — Firewall and DMZ Architecture**

A firewall sits between the bank's internal network and the internet. The Demilitarized Zone (DMZ) is configured to hold internet-facing servers (web servers, API gateways) while keeping the core banking database strictly internal. Justification: Even if the DMZ is compromised, the CBS data remains protected behind an additional perimeter.

- **Layer 3 — Restricting Administrative Privileges**

Limiting who can access sensitive data and configurations reduces the attack surface. Role-based access control (RBAC) ensures that a front-end developer cannot access the treasury system. Justification: The Maker-Checker principle in banking directly maps to this — no single person should have end-to-end control over a transaction.

- **Layer 4 — Data Encryption**

All data at rest (stored customer data, logs) and in transit (API calls, internet banking sessions) must be encrypted. Decryption keys should be managed under strict key management policies. Justification: Even if data is exfiltrated, encryption makes it unusable to the attacker.

- **Layer 5 — Two-Factor Authentication (2FA)**

For all customer-facing interfaces and all administrative access, 2FA must be mandatory. A password combined with a one-time code generated by an app is the minimum. Justification: Single-factor authentication is the single most commonly exploited vulnerability in banking.

- **Layer 6 — Security Testing in SDLC**

Every release of new banking software must go through the full testing cycle: Unit, White Box, Black Box, Integration, Stress, Security, UAT, and Beta Testing. Trapdoors and Salami Attacks

must be specifically looked for in code reviews. Justification: A vulnerability left undetected at Beta stage will surface in production with far greater damage.

- **Layer 7 — Employee Training**

Technology alone is not enough. Every employee must know how to recognise phishing attempts, protect their credentials, and follow access control protocols. Justification: The human element remains the weakest link — training directly addresses this.

Q13. Evaluate the security architecture required for banks moving towards a paperless, Core Banking-driven environment. Consider the roles of software controls, operational procedures, and user-level controls in building a secure banking ecosystem.

Answer: India's banking sector is at an inflection point — Core Banking Solutions have replaced branch-bound ledgers, Digital India has pushed e-governance into mainstream use, and RBI has consistently moved towards a paperless, chequeless, cashless model.

Securing this ecosystem is no longer just an IT department concern — it is a governance imperative.

1. Software Controls:

- At the core of a paperless bank is the CBS application. Securing it begins with controlling who can access what. Role-based access control must be implemented so that a data entry operator can post transactions but cannot modify account master data. Session-generated PINs (as used by some private banks) ensure that even if a customer's credentials are compromised, each transaction session has a unique authentication token.
- For internet banking and mobile banking, the DMZ architecture ensures that public-facing systems are segregated from the CBS backend. Firewalls, intrusion detection systems, and regular security testing are non-negotiable components.
- The SDLC itself must embed security — White Box Testing to catch trapdoors and Salami Attacks, Black Box Testing to validate access controls, and Security Testing to verify compliance with IS Policy and access privilege configurations.

2. Operational Procedures:

- Operational security in a bank starts from the moment a voucher (physical or electronic) is generated. The Maker-Checker principle must be enforced — no single person should both initiate and authorise a transaction. This applies to both manual and system-generated entries.
- Exception reports are the operational security safety net — transactions that fall outside normal parameters (temporary overdrafts, accounts opened without proper introduction, excess drawings in Cash Credit accounts) must be flagged automatically and reviewed by branch managers. These reports must be preserved and escalated as part of the operational control architecture.
- Service Level Agreements with third-party vendors and cloud providers must explicitly define security obligations and include penalty provisions for breaches.

3. User-Level Controls:

- Field officers and operational staff are the last line of defence. Their ability to recognise and report abnormal transactions — what the textbook calls 'exception reports' — is as important as any automated control. Training and awareness programs, as recommended by the Gopalakrishna Working Group, must cover all cadres of staff as well as customers, sensitising them to PIN protection, phishing, and cyber fraud.

- Physical access to terminals must be governed by automatic screen locks and session timeouts. Staff working from outside the intranet must access CBS only through authenticated VPN channels, with logical access monitored continuously.

4. Conclusion:

A truly secure paperless banking environment is the product of software controls, operational discipline, and human awareness working in concert. None of the three is sufficient alone — a perfectly coded CBS can be compromised by a careless employee, and the most vigilant staff cannot compensate for an unpatched vulnerability in the internet banking stack. Security in banking is, ultimately, a chain — and its strength is that of its weakest link.

Q14. Construct a comprehensive Operational Security policy framework for a mid-sized BPO company that handles financial data for multiple banking clients. Your framework should address personnel, technology, third-party access, and compliance.

Answer: A BPO company handling financial data for banks sits at a unique intersection — it must satisfy the security requirements of multiple banking clients, each with their own regulatory obligations under RBI, SEBI, and the IT Act, while managing its own operational risks.

Section 1: Personnel Security

- All employees must undergo background verification before onboarding, including financial history checks relevant to the nature of data handled. Role-based access must be assigned at the time of onboarding, and no employee should have access beyond what their job requires.
- Awareness training must be conducted at joining and at regular intervals, at minimum on an annual basis. Topics must include phishing recognition, clean desk policies, prohibition on external device use, and the legal consequences of data leakage under the IT Act.
- A clear Code of Conduct must be signed by all employees, with specific clauses covering data confidentiality and the prohibition of unauthorised data copying or transmission.

Section 2: Technology Controls

- All workstations must have USB ports disabled or blocked through endpoint security software. Only company-approved communication channels may be used for work-related communication, and personal email or messaging applications are strictly prohibited.
- Data at rest and in transit must be encrypted. Access to financial records must be through authenticated and logged sessions, with every data access event recorded in a tamper-proof audit trail.
- Firewalls, intrusion detection systems, and regular vulnerability assessments must be maintained. Patches must be applied within a defined timeline, for instance critical patches within 48 hours of release.
- Two-factor authentication must be mandatory for all access to client data systems.

Section 3: Third-Party Access Controls

- All vendor and contractor access must be governed by a formal SLA. The agreement must explicitly restrict access to only the systems required for the contracted work. It must require vendors to maintain their own security standards and submit periodic proof of compliance. Penalty clauses must be included for any breach resulting from vendor actions, and vendors must be obligated to notify the company within a defined window, such as four hours, in the event of a suspected breach.

- Third-party sessions must be monitored in real time wherever technically feasible. All third-party access logs must be preserved for the minimum period mandated by the IT Act.

Section 4: Compliance Framework

- The company must comply with the IT Act, 2000 and its amendments, including the Due Diligence obligations under Section 79 applicable to intermediaries. Each banking client's regulatory requirements, covering RBI guidelines and SEBI mandates, must be individually mapped and tracked.
- A dedicated Information Security Officer must be appointed with a clearly defined Key Responsibility Area to own compliance monitoring. Regular internal audits and at least one external audit per year must be conducted.
- Incident response procedures must be documented and tested through tabletop exercises. In the event of a security incident, a defined escalation matrix must ensure that affected banking clients are notified within the agreed SLA timeline.

Section 5: Monitoring and Review

- Exception reports must be generated for any anomalous access pattern, including large volume downloads, access at unusual hours, or access to data falling outside the employee's assigned scope. The Information Security Officer must review these within 24 hours.
- The policy framework must be reviewed annually or whenever there is a significant change in the regulatory environment or in the nature of data handled. Effectiveness metrics such as number of incidents, mean time to detect, and mean time to respond must be tracked and reported to senior management on a quarterly basis.

Q15. Drawing from the concepts of Software and Operational Security, construct a Security Audit checklist for a bank that is about to go live with a new Core Banking Solution. Your checklist should span software testing, access controls, operational readiness, and cloud infrastructure (if applicable).

Answer: Going live with a new CBS is one of the highest-risk transitions a bank undertakes. The following audit checklist covers all critical domains that must be verified before go-live.

A. Software Testing Readiness

- Unit Testing completed and sign-off obtained from the development team
- White Box Testing conducted, with source code reviewed for trapdoors, Salami Attack vectors, and hardcoded credentials
- Black Box Testing completed, with all user-facing interfaces tested for input validation and access boundary violations
- Integration Testing done, confirming that the CBS has been tested with all peripheral systems including ATM switches, RTGS/NEFT gateways, and the internet banking platform
- Volume and Stress Testing conducted, with the system tested at twice the expected peak load
- Security Testing completed, verifying IS Policy compliance, DoS/DDoS resilience, and DMZ configuration
- User Acceptance Testing sign-off obtained from the operations team
- Alpha and Beta Testing cycles completed with documented defect closure

B. Access Control and Authentication

- Role-based access control implemented, with each user role carrying the minimum necessary access
- Maker-Checker principle enforced for all financial transactions
- Two-factor authentication active for all internet banking and administrative interfaces
- Session timeout configured so that idle sessions auto-lock after a defined period
- Default passwords changed on all system accounts
- Privileged access for DBA and system administrators logged and monitored
- Access provisioning and de-provisioning process documented and tested

C. Operational Readiness

- Exception report generation tested to confirm overdrafts and abnormal transactions are flagged correctly
- Escalation matrix documented, specifying who receives exception reports and within what timeframe
- Disaster Recovery and Business Continuity Plan tested for a CBS failover scenario
- Staff training completed, with operational staff trained on new system workflows and security protocols
- Audit trail enabled for all transactions, with records retained as per RBI guidelines
- Maker-Checker logs verified to confirm no single-person end-to-end transaction approval is possible
- Physical security at the data centre reviewed, covering access logs, CCTV, and biometric entry controls

D. Cloud Infrastructure (if applicable)

- Cloud service provider's compliance certifications reviewed, including ISO 27001 and SOC 2
- Data residency confirmed, with customer data stored within India as per RBI localisation requirements
- SLA reviewed to confirm it contains uptime guarantees, security obligations, breach notification timelines, and penalty clauses
- Encryption at rest and in transit configured and verified
- IAM policies reviewed to ensure no overprivileged service accounts exist
- Network segmentation between the bank's cloud environment and other tenants confirmed
- Incident response coordination process agreed upon with the cloud provider

E. Compliance and Governance

- CBS configuration reviewed against RBI IS guidelines and Gopalakrishna Committee recommendations
- CERT-In incident reporting obligations understood and the response process documented
- Is Security Policy updated to reflect the new CBS environment
- Third-party vendor and software SLAs reviewed for security obligations
- Go-live approval obtained from the CISO and top management

This checklist must be treated as a living document. Any deficiency identified must be resolved before go-live, and all items earmarked for post-go-live monitoring must be assigned clear ownership with defined review timelines.

.